



ARKA HEALTH, INC.

AUDIT LOGGING & MONITORING POLICY

*Audit controls and information-system activity review — 45 C.F.R. §§ 164.312(b), 164.308(a)(1)(ii)
(D)*

ARKA-SEC-005 · Version 1.0 · Confidential — Internal

Document No.	ARKA-SEC-005
Version	1.0
Effective Date	June 10, 2026
Last Reviewed	June 10, 2026
Document Owner	Arri Kanna, Founder & Chief Executive Officer — Privacy & Security Officer
Approved By	Arri Kanna, Founder & Chief Executive Officer
Classification	Confidential — Internal
Review Cycle	Annual, and upon any material change in operations, systems, or law

This document contains confidential and proprietary information of ARKA Health, Inc. (“ARKA”). It is furnished for informational and compliance purposes, may not be reproduced or disclosed to any third party without the prior written consent of ARKA, and must be returned or destroyed upon request. Nothing in this document constitutes legal advice.

1. PURPOSE

This Policy implements the Audit Controls standard, 45 C.F.R. § 164.312(b), and the Information System Activity Review implementation specification, 45 C.F.R. § 164.308(a)(1)(ii)(D), by requiring ARKA Health, Inc. to record and examine activity in information systems that contain or use ePHI, and to detect, in a timely manner, unauthorized access, anomalous behavior, and control failures.

2. EVENTS RECORDED

At a minimum, in-scope systems shall log: authentication events (success, failure, MFA challenge outcomes, break-glass use); authorization failures; creation, reading, updating, deletion, and export of records containing ePHI, attributed to the acting identity and tenant; administrative actions (role grants, configuration changes, key operations); deployment events with the associated change identifier (ARKA-SEC-010); and security-relevant infrastructure events (provider audit trails such as AWS CloudTrail, Vercel audit logs, Supabase database logs). Each entry shall record the actor, action, object, tenant, timestamp in UTC, and originating source, synchronized to authoritative time.

3. PROTECTION OF LOG DATA

1. Logs are transmitted to centralized, access-controlled storage segregated from the systems that generate them; write access for producers is append-only, and modification or deletion of stored log entries is technically prevented for the duration of the retention period.
2. Log content is minimized: application logs shall not record ePHI field values, authentication secrets, or full tokens; structured event identifiers and record references are used instead, consistent with the redaction conventions in docs/PHI_REDACTION.md of the platform repository.
3. Access to logs is restricted to the Security Officer and designated engineering personnel and is itself logged.
4. Security-relevant logs are retained **six (6) years** in accordance with 45 C.F.R. § 164.316(b)(2)(i); high-volume operational telemetry without security relevance may follow shorter schedules under ARKA-SEC-011.

4. REVIEW AND ALERTING

Automated alerting shall notify the Security Officer in near-real time of: repeated authentication failures and impossible-travel patterns; break-glass account use; privilege escalations; disabling or misconfiguration of logging; mass-export or anomalous-volume queries against ePHI stores; and production deployments outside change control. In addition to automated alerting, the Security Officer shall conduct and document a **weekly** review of security dashboards and a **monthly** sampled review of access logs for ePHI-bearing systems, with findings, escalations, and corrective actions recorded in the activity-review log. Suspected incidents identified through review are handled under ARKA-SEC-006.

5. CUSTOMER AUDIT SUPPORT

Where required by a BAA, ARKA shall make available to a Customer, within fifteen (15) business days of a written request, audit-trail extracts pertaining to that Customer's tenant sufficient to support the Customer's own § 164.308(a)(1)(ii)(D) reviews and accounting obligations, in a machine-readable format.

DOCUMENT CONTROL & REVISION HISTORY

Version	Date	Author / Reviewer	Description of Change
0.9	May 22, 2026	A. Kanna (drafting); external review pending	Initial draft circulated for internal review and counsel comment.
1.0	June 10, 2026	A. Kanna, Privacy & Security Officer	Adopted as effective policy of ARKA Health, Inc. by written approval of the undersigned officer.

ADOPTION AND APPROVAL

The undersigned, being the duly designated Privacy Officer and Security Officer of ARKA Health, Inc., hereby adopts this document as an official policy of the Company, effective as of the Effective Date set forth on the cover page hereof. This document shall be reviewed no less frequently than annually and upon any material change to the Company's operations, information systems, or applicable law, and may be amended only in accordance with ARKA-GOV-001 (Information Security & Compliance Program Charter).

ARKA HEALTH, INC.

By: _____

Name: Arri Kanna

Title: Founder & Chief Executive Officer; Privacy & Security Officer

Date: June 10, 2026